Skyveda Health Report

Sample report · fictional online retailer · not a real customer

AZURE · 3 scope(s) · scanned 10 Nov 2026, 11:02 UTC · Skyveda 0.5.0 · **offline data**

Read-only scan: nothing in the environment was created, changed or deleted.

Summary

OVERALL SCORE	FINDINGS	WASTE	CHECKS
35/100	**42** 2 critical · 14 high · 20 medium · 6 low	**₹55,282** a month · ₹53,426 billed, ₹1,856 list-price estimate	**60** 18 passed · 42 failed · 0 not scored

Scores by area

AREA	SCORE	PASSED	FAILED
Kubernetes (AKS)	**68**	3	2
Network	**12**	2	11
Identity	**35**	2	5
Security	**42**	8	11
Reliability	**33**	2	6
Cost	**19**	1	7

Framework summary

Checks passed and failed against each Well-Architected pillar and each Microsoft cloud security benchmark (MCSB) control. Checks not scored are left out.

WELL-ARCHITECTED PILLAR	PASSED	FAILED
Cost Optimization	1	7
Reliability	3	5
Security	14	30

MCSB CONTROL	PASSED	FAILED
DP-3	5	3
DP-8	0	1
IM-1	2	6
IM-3	0	2
IM-6	0	1
NS-1	1	3
NS-2	2	10
PA-7	2	0
PV-2	2	2
PV-4	0	1
PV-6	0	1

Findings

CRITICAL Failed: No SSH or RDP open to the Internet

AZ-NET-001 · Network · 2 resource(s)

Maps to: MCSB NS-1 · WAF SE:06 (Security)

Why it matters. An inbound rule that allows SSH or RDP from the Internet exposes servers to constant password-guessing and exploit attempts. It is one of the most common ways cloud servers are breached.

Fix. Remove the rule, or limit its source to known addresses and use Azure Bastion or just-in-time access.

1. Open the network security group and find the rules listed in the evidence.
2. Delete the rule, or change its source from Internet or * to your office or VPN address range.
3. For admin access, use Azure Bastion or Defender for Cloud just-in-time VM access instead.

```
az network nsg rule update -g <resource-group> --nsg-name <nsg> -n <rule> --source-address-prefixes
<your-ip>/32
```

NAME	EVIDENCE	RESOURCE ID
nsg-vm-erp-01	**resourceGroup**: rg-shop-app-prod-cin **exposedRules**: ["allow-rdp-vendor"] **checkedPorts**: [22, 3389]	/subscriptions/00000000-0000-0000-0000-00000000d001/resourceGroups/rg-shop-app-prod-cin/providers/Microsoft.Network/networkSecurityGroups/nsg-vm-erp-01
nsg-snet-jumpbox	**resourceGroup**: rg-platform-tools-cin **exposedRules**: ["allow-ssh"] **checkedPorts**: [22, 3389]	/subscriptions/00000000-0000-0000-0000-00000000d003/resourceGroups/rg-platform-tools-cin/providers/Microsoft.Network/networkSecurityGroups/nsg-snet-jumpbox

Reference: https://learn.microsoft.com/azure/virtual-network/network-security-groups-overview

CRITICAL Failed: Azure SQL server firewall does not allow the whole internet

AZ-SQL-002 · Network · 1 resource(s)

Maps to: MCSB NS-2 · WAF SE:06 (Security)

Why it matters. A firewall rule covering 0.0.0.0 to 255.255.255.255 lets every address on the internet reach the database login endpoint. Attackers scan for these constantly and try stolen or guessed passwords.

Fix. Delete the allow-all rule and allow only the addresses that need access.

1. Find which clients really connect (office, build agents, app outbound IPs).
2. Add narrow rules, or better, use private endpoints or virtual network rules.
3. Delete the 0.0.0.0 - 255.255.255.255 rule.

```
az sql server firewall-rule delete -g <resource-group> -s <server> -n <rule-name>
```

NAME	EVIDENCE	RESOURCE ID
AllowAll-temp	**resourceGroup**: rg-shop-db-uat-cin **location**: centralindia **server**: sql-shop-uat-cin **startIp**: 0.0.0.0 **endIp**: 255.255.255.255	/subscriptions/00000000-0000-0000-0000-00000000d002/resourceGroups/rg-shop-db-uat-cin/providers/Microsoft.Sql/servers/sql-shop-uat-cin/firewallRules/AllowAll-temp

Reference: https://learn.microsoft.com/azure/azure-sql/database/firewall-configure

HIGH Failed: Azure SQL servers use Microsoft Entra-only authentication

AZ-SQL-001 · Identity · 2 resource(s)

Maps to: MCSB IM-1 · WAF SE:05 (Security)

Why it matters. SQL logins use passwords that get shared, leaked and rarely rotated. With Microsoft Entra-only authentication, every connection goes through an identity that has MFA, conditional access and a central audit trail, and SQL passwords stop working.

Fix. Set a Microsoft Entra admin and turn on Microsoft Entra-only authentication.

1. Set a Microsoft Entra admin (preferably a group) on the SQL server.
2. Move applications to managed identities or Entra users, and test them.
3. Enable "Support only Microsoft Entra authentication for this server" under Microsoft Entra ID.

```
az sql server ad-only-auth enable -g <resource-group> -n <server>
```

NAME	EVIDENCE	RESOURCE ID
sql-shop-reports-prod-cin	**resourceGroup**: rg-shop-db-prod-cin **location**: centralindia **entraOnlyAuth**: false	/subscriptions/00000000-0000-0000-0000-00000000d001/resourceGroups/rg-shop-db-prod-cin/providers/Microsoft.Sql/servers/sql-shop-reports-prod-cin
sql-shop-uat-cin	**resourceGroup**: rg-shop-db-uat-cin **location**: centralindia **entraOnlyAuth**: false	/subscriptions/00000000-0000-0000-0000-00000000d002/resourceGroups/rg-shop-db-uat-cin/providers/Microsoft.Sql/servers/sql-shop-uat-cin

Reference: https://learn.microsoft.com/azure/azure-sql/database/authentication-azure-ad-only-authentication

HIGH Failed: AKS clusters use Entra ID only, with local accounts disabled

AZ-AKS-002 · Kubernetes (AKS) · 2 resource(s)

Maps to: MCSB IM-1 · WAF SE:05 (Security)

Why it matters. Local Kubernetes accounts use static credentials that bypass Entra ID sign-in, conditional access and audit. Anyone holding the admin kubeconfig keeps full control even after leaving.

Fix. Integrate the cluster with Entra ID and disable local accounts.

1. Make sure Entra ID integration is enabled and an admin group is set.
2. Move any automation from the admin kubeconfig to Entra-based credentials.
3. Disable local accounts.

```
az aks update -g <resource-group> -n <cluster> --enable-aad --disable-local-accounts
```

NAME	EVIDENCE	RESOURCE ID
aks-shop-prod-cin	**resourceGroup**: rg-shop-aks-prod-cin **location**: centralindia **disableLocalAccounts**: false **entraManaged**: true	/subscriptions/00000000-0000-0000-0000-00000000d001/resourceGroups/rg-shop-aks-prod-cin/providers/Microsoft.ContainerService/managedClusters/aks-shop-prod-cin
aks-shop-uat-cin	**resourceGroup**: rg-shop-aks-uat-cin **location**: centralindia **disableLocalAccounts**: false **entraManaged**: false	/subscriptions/00000000-0000-0000-0000-00000000d002/resourceGroups/rg-shop-aks-uat-cin/providers/Microsoft.ContainerService/managedClusters/aks-shop-uat-cin

Reference: https://learn.microsoft.com/azure/aks/manage-local-accounts-managed-azure-ad

HIGH Failed: Cosmos DB accounts are not open to all networks

AZ-COSMOS-002 · Network · 1 resource(s)

Maps to: MCSB NS-2 · WAF SE:06 (Security)

Why it matters. An account that accepts connections from any network relies on its keys alone. A leaked key can then be used from anywhere on the Internet to read or change every database in the account.

Fix. Use private endpoints and disable public access, or limit public access to known networks.

1. List the networks and addresses that must reach the account.
2. Add a private endpoint, or add IP and virtual network rules in the account's Networking settings.
3. Set public network access to Disabled, or to selected networks only.

```
az cosmosdb update -g <resource-group> -n <account> --public-network-access Disabled
```

NAME	EVIDENCE	RESOURCE ID
cosmos-shop-catalog-uat-cin	**resourceGroup**: rg-shop-data-uat-cin **location**: centralindia **publicNetworkAccess**: Enabled **ipRules**: 0 **vnetFilter**: false	/subscriptions/00000000-0000-0000-0000-00000000d002/resourceGroups/rg-shop-data-uat-cin/providers/Microsoft.DocumentDB/databaseAccounts/cosmos-shop-catalog-uat-cin

Reference: https://learn.microsoft.com/azure/cosmos-db/how-to-configure-firewall

HIGH Failed: Key Vaults are not open to all networks

AZ-KV-003 · Network · 2 resource(s)

Maps to: MCSB NS-2 · WAF SE:06 (Security)

Why it matters. A vault that accepts connections from any network can be reached from the Internet by anyone who gets hold of a credential. A firewall that denies by default limits it to named networks.

Fix. Set the vault firewall to deny by default and allow only the networks that need it, or turn public access off.

1. List who and what reaches the vault today (applications, pipelines, admins).
2. Add private endpoints or virtual network rules for them, then set the default action to Deny.
3. Where private endpoints carry all access, set public network access to Disabled.

```
az keyvault update -g <resource-group> -n <vault> --default-action Deny
```

NAME	EVIDENCE	RESOURCE ID
kv-payments-prod-cin	**resourceGroup**: rg-shop-sec-prod-cin **location**: centralindia **publicNetworkAccess**: Enabled **defaultAction**: Allow	/subscriptions/00000000-0000-0000-0000-00000000d001/resourceGroups/rg-shop-sec-prod-cin/providers/Microsoft.KeyVault/vaults/kv-payments-prod-cin
kv-shop-uat-cin	**resourceGroup**: rg-shop-sec-uat-cin **location**: centralindia **publicNetworkAccess**: Enabled **defaultAction**: Allow	/subscriptions/00000000-0000-0000-0000-00000000d002/resourceGroups/rg-shop-sec-uat-cin/providers/Microsoft.KeyVault/vaults/kv-shop-uat-cin

Reference: https://learn.microsoft.com/azure/key-vault/general/network-security

HIGH Failed: Storage, Key Vault and SQL are reached through private endpoints

AZ-NET-002 · Network · 5 resource(s)

Maps to: MCSB NS-2 · WAF SE:06 (Security)

Why it matters. Without a private endpoint, data services are reached over public addresses. One wrong firewall setting then exposes data stores to the Internet.

Fix. Add a private endpoint, then turn off public network access.

1. Create a private endpoint in the application's virtual network and link the private DNS zone.
2. When applications use the endpoint, set public network access to Disabled.

NAME	EVIDENCE	RESOURCE ID
stshopmediaprodcin	**resourceGroup**: rg-shop-data-prod-cin **location**: centralindia **type**: microsoft.storage/storageaccounts **privateEndpoints**: 0 **publicNetworkAccess**: Enabled	`/subscriptions/00000000-0000-0000-0000-00000000d001/resourceGroups/rg-shop-data-prod-cin/providers/Microsoft.Storage/storageAccounts/stshopmediaprodcin`
stshopexportsuatcin	**resourceGroup**: rg-shop-data-uat-cin **location**: centralindia **type**: microsoft.storage/storageaccounts **privateEndpoints**: 0 **publicNetworkAccess**: Enabled	`/subscriptions/00000000-0000-0000-0000-00000000d002/resourceGroups/rg-shop-data-uat-cin/providers/Microsoft.Storage/storageAccounts/stshopexportsuatcin`
kv-payments-prod-cin	**resourceGroup**: rg-shop-sec-prod-cin **location**: centralindia **type**: microsoft.keyvault/vaults **privateEndpoints**: 0 **publicNetworkAccess**: Enabled	`/subscriptions/00000000-0000-0000-0000-00000000d001/resourceGroups/rg-shop-sec-prod-cin/providers/Microsoft.KeyVault/vaults/kv-payments-prod-cin`
sql-shop-prod-cin	**resourceGroup**: rg-shop-db-prod-cin **location**: centralindia **type**: microsoft.sql/servers **privateEndpoints**: 0 **publicNetworkAccess**: Enabled	`/subscriptions/00000000-0000-0000-0000-00000000d001/resourceGroups/rg-shop-db-prod-cin/providers/Microsoft.Sql/servers/sql-shop-prod-cin`
sql-shop-uat-cin	**resourceGroup**: rg-shop-db-uat-cin **location**: centralindia **type**: microsoft.sql/servers **privateEndpoints**: 0 **publicNetworkAccess**: Enabled	`/subscriptions/00000000-0000-0000-0000-00000000d002/resourceGroups/rg-shop-db-uat-cin/providers/Microsoft.Sql/servers/sql-shop-uat-cin`

Reference: https://learn.microsoft.com/azure/private-link/private-endpoint-overview

HIGH Failed: Storage accounts deny public network access by default

AZ-NET-004 · Network · 2 resource(s)

Maps to: MCSB NS-2 · WAF SE:06 (Security)

Why it matters. A storage account whose firewall allows all networks can be reached from the Internet by anyone who holds a key or a token. A firewall that denies by default limits access to named networks.

Fix. Set the storage firewall to deny by default and allow only the networks that need it, or turn public access off.

1. List who and what reaches the account today (applications, pipelines, admins).
2. Add private endpoints or virtual network rules for them, then set the default action to Deny.
3. Where private endpoints carry all access, set public network access to Disabled.

```
az storage account update -g <resource-group> -n <account> --default-action Deny
```

NAME	EVIDENCE	RESOURCE ID
stshopstaticprodcin	**resourceGroup**: rg-shop-web-prod-cin **location**: centralindia **publicNetworkAccess**: Enabled **defaultAction**: Allow	`/subscriptions/00000000-0000-0000-0000-00000000d001/resourceGroups/rg-shop-web-prod-cin/providers/Microsoft.Storage/storageAccounts/stshopstaticprodcin`
stshopexportsuatcin	**resourceGroup**: rg-shop-data-uat-cin **location**: centralindia **publicNetworkAccess**: Enabled **defaultAction**: Allow	`/subscriptions/00000000-0000-0000-0000-00000000d002/resourceGroups/rg-shop-data-uat-cin/providers/Microsoft.Storage/storageAccounts/stshopexportsuatcin`

Reference: https://learn.microsoft.com/azure/storage/common/storage-network-security

HIGH Failed: No database ports open to the Internet

AZ-NET-006 · Network · 1 resource(s)

Maps to: MCSB NS-1 · WAF SE:06 (Security)

Why it matters. An inbound rule that lets the Internet reach a database port invites password guessing and exploits against the database itself. Exposed databases are found by automated scanners within hours, and are a common source of data breaches and ransom demands.

Fix. Remove the rule, or limit its source to the application's own network or known addresses.

1. Open the network security group and find the rules listed in the evidence.
2. Delete the rule, or change its source from Internet or * to the subnet or addresses that need the database.
3. Prefer private endpoints or virtual network integration so the database has no public path at all.

```
az network nsg rule update -g <resource-group> --nsg-name <nsg> -n <rule> --source-address-prefixes
<app-subnet-cidr>
```

NAME	EVIDENCE	RESOURCE ID
nsg-vm-erp-01	**resourceGroup**: rg-shop-app-prod-cin **exposedRules**: ["allow-sql-anywhere"] **checkedPorts**: [1433, 1521, 3306, 5432, 6379, 6380, 9200, 27017]	/subscriptions/00000000-0000-0000-0000-00000000d001/resourceGroups/rg-shop-app-prod-cin/providers/Microsoft.Network/networkSecurityGroups/nsg-vm-erp-01

Reference: https://learn.microsoft.com/azure/virtual-network/network-security-groups-overview

HIGH Failed: PostgreSQL and MySQL flexible servers disable public network access

AZ-PGSQL-001 · Network · 1 resource(s)

Maps to: MCSB NS-2 · WAF SE:06 (Security)

Why it matters. A database server with a public endpoint can be reached from the Internet whenever a firewall rule allows it, and such rules are often widened in a hurry. Private access keeps the server reachable only from your own networks.

Fix. Reach the server through a private endpoint or virtual network, and disable public access.

1. Add a private endpoint for the server, or plan a move to virtual network integration.
2. Point applications at the private address and check they still connect.
3. Set public network access to Disabled in the server's Networking settings.

```
az postgres flexible-server update -g <resource-group> -n <server> --public-access Disabled
```

NAME	EVIDENCE	RESOURCE ID
mysql-shop-blog-prod-cin	**resourceGroup**: rg-shop-web-prod-cin **location**: centralindia **engine**: MySQL **publicNetworkAccess**: Enabled	/subscriptions/00000000-0000-0000-0000-00000000d001/resourceGroups/rg-shop-web-prod-cin/providers/Microsoft.DBforMySQL/flexibleServers/mysql-shop-blog-prod-cin

Reference: https://learn.microsoft.com/azure/postgresql/flexible-server/concepts-networking · https://learn.microsoft.com/azure/mysql/flexible-server/concepts-networking

HIGH Failed: Azure SQL servers disable public network access

AZ-SQL-003 · Network · 2 resource(s)

Maps to: MCSB NS-2 · WAF SE:06 (Security)

Why it matters. With public network access enabled the server answers connections from the internet, protected only by its firewall rules. Disabling it, and connecting through private endpoints, keeps the database reachable only from inside your own networks.

Fix. Disable public network access and connect through a private endpoint.

1. Create a private endpoint for the SQL server in the network your applications use.
2. Check that applications connect through the private endpoint (private DNS zone linked).
3. Set "Public network access" to Disabled under the server's Networking settings.

```
az sql server update -g <resource-group> -n <server> --enable-public-network false
```

NAME	EVIDENCE	RESOURCE ID
sql-shop-reports-prod-cin	**resourceGroup**: rg-shop-db-prod-cin **location**: centralindia **publicNetworkAccess**: Enabled **privateEndpoints**: 0	`/subscriptions/00000000-0000-0000-0000-00000000d001/resourceGroups/rg-shop-db-prod-cin/providers/Microsoft.Sql/servers/sql-shop-reports-prod-cin`
sql-shop-uat-cin	**resourceGroup**: rg-shop-db-uat-cin **location**: centralindia **publicNetworkAccess**: Enabled **privateEndpoints**: 0	`/subscriptions/00000000-0000-0000-0000-00000000d002/resourceGroups/rg-shop-db-uat-cin/providers/Microsoft.Sql/servers/sql-shop-uat-cin`

Reference: https://learn.microsoft.com/azure/azure-sql/database/connectivity-settings

HIGH Failed: No Basic SKU load balancers

AZ-NET-008 · Reliability · 1 resource(s)

Maps to: WAF RE:05 (Reliability)

Why it matters. Microsoft retired the Basic load balancer on 30 September 2025. It is no longer supported and has no SLA, so a fault in it is not covered and may not be fixed. It also has no availability zone support.

Fix. Upgrade each Basic load balancer to the Standard SKU.

1. Plan a short outage, because the upgrade recreates the load balancer's frontends.
2. Run Microsoft's upgrade script, which moves the configuration and backend pools to a Standard load balancer.
3. Check that network security groups allow the traffic, because Standard denies inbound by default.

NAME	EVIDENCE	RESOURCE ID
lb-shop-checkout-old	**resourceGroup**: rg-shop-net-prod-cin **location**: centralindia **sku**: Basic **frontends**: 1	`/subscriptions/00000000-0000-0000-0000-00000000d001/resourceGroups/rg-shop-net-prod-cin/providers/Microsoft.Network/loadBalancers/lb-shop-checkout-old`

Reference: https://learn.microsoft.com/azure/load-balancer/load-balancer-basic-upgrade-guidance

HIGH Failed: Key Vaults have soft delete and purge protection

AZ-KV-001 · Security · 2 resource(s)

Maps to: MCSB DP-8 · WAF pillar Security

Why it matters. Without purge protection, a deleted vault and its keys and secrets can be permanently destroyed at once, by mistake or by an attacker, with no way to recover them.

Fix. Turn on purge protection (soft delete must also be on).

1. Note that purge protection cannot be turned off once enabled; this is intended.
2. Enable purge protection in the vault's Properties settings.

```
az keyvault update -g <resource-group> -n <vault> --enable-purge-protection true
```

NAME	EVIDENCE	RESOURCE ID
kv-payments-prod-cin	**resourceGroup**: rg-shop-sec-prod-cin **location**: centralindia **softDelete**: true **purgeProtection**: null	/subscriptions/00000000-0000-0000-0000-00000000d001/resourceGroups/rg-shop-sec-prod-cin/providers/Microsoft.KeyVault/vaults/kv-payments-prod-cin
kv-shop-uat-cin	**resourceGroup**: rg-shop-sec-uat-cin **location**: centralindia **softDelete**: true **purgeProtection**: null	/subscriptions/00000000-0000-0000-0000-00000000d002/resourceGroups/rg-shop-sec-uat-cin/providers/Microsoft.KeyVault/vaults/kv-shop-uat-cin

Reference: https://learn.microsoft.com/azure/key-vault/general/soft-delete-overview

HIGH Failed: Azure Cache for Redis has the non-TLS port disabled

AZ-REDIS-001 · Security · 1 resource(s)

Maps to: MCSB DP-3 · WAF SE:07 (Security)

Why it matters. The non-TLS port (6379) sends the access key and every cached value in clear text. Anyone on the network path can read session tokens, user data or the key itself, and then the whole cache.

Fix. Disable the non-TLS port and connect on port 6380 over TLS.

1. Find clients that connect on port 6379 and move them to port 6380 with TLS turned on.
2. Disable the non-TLS port in the cache's Advanced settings.

```
az redis update -g <resource-group> -n <cache> --set enableNonSslPort=false
```

NAME	EVIDENCE	RESOURCE ID
redis-shop-sessions-uat-cin	**resourceGroup**: rg-shop-data-uat-cin **location**: centralindia **enableNonSslPort**: true	/subscriptions/00000000-0000-0000-0000-00000000d002/resourceGroups/rg-shop-data-uat-cin/providers/Microsoft.Cache/redis/redis-shop-sessions-uat-cin

Reference: https://learn.microsoft.com/azure/azure-cache-for-redis/cache-configure#access-ports

HIGH Failed: Storage accounts block anonymous blob access

AZ-STG-001 · Security · 2 resource(s)

Maps to: MCSB NS-2 · WAF SE:05 (Security)

Why it matters. When anonymous access is allowed at the account level, a single container set to public exposes its files to anyone with the link. Blocking it at the account level removes that risk.

Fix. Disallow anonymous blob access on the storage account.

1. Check that no application relies on anonymous reads from these accounts.
2. Turn off "Allow Blob anonymous access" in the account's Configuration settings.

```
az storage account update -g <resource-group> -n <account> --allow-blob-public-access false
```

NAME	EVIDENCE	RESOURCE ID
stshopstaticprodcin	**resourceGroup**: rg-shop-web-prod-cin **location**: centralindia **allowBlobPublicAccess**: true	/subscriptions/00000000-0000-0000-0000-00000000d001/resourceGroups/rg-shop-web-prod-cin/providers/Microsoft.Storage/storageAccounts/stshopstaticprodcin
stshopexportsuatcin	**resourceGroup**: rg-shop-data-uat-cin **location**: centralindia **allowBlobPublicAccess**: true	/subscriptions/00000000-0000-0000-0000-00000000d002/resourceGroups/rg-shop-data-uat-cin/providers/Microsoft.Storage/storageAccounts/stshopexportsuatcin

Reference: https://learn.microsoft.com/azure/storage/blobs/anonymous-read-access-prevent

HIGH Failed: Linux virtual machines disable password sign-in

AZ-VM-001 · Security · 1 resource(s)

Maps to: MCSB IM-6 · WAF SE:05 (Security)

Why it matters. A Linux server that accepts passwords can be broken into by guessing them, and bots try this against every reachable address all day. SSH keys cannot be guessed and are not reused across sites the way passwords are.

Fix. Sign in with SSH keys or Entra ID, and turn off password authentication.

1. Make sure every admin can sign in with an SSH key or with Entra ID login for Linux.
2. Set PasswordAuthentication no in /etc/ssh/sshd_config and restart sshd.
3. For new VMs, create them with SSH keys only so the setting is recorded on the VM.

NAME	EVIDENCE	RESOURCE ID
vm-uat-02	**resourceGroup**: rg-shop-app-uat-cin **location**: centralindia **disablePasswordAuthentication**: false	`/subscriptions/00000000-0000-0000-0000-00000000d002/resourceGroups/rg-shop-app-uat-cin/providers/Microsoft.Compute/virtualMachines/vm-uat-02`

Reference: https://learn.microsoft.com/azure/virtual-machines/linux/create-ssh-keys-detailed

MEDIUM Failed: No unattached managed disks

AZ-COST-001 · Cost · 5 resource(s) · **₹24,425 a month, billed**

Maps to: WAF CO:07 (Cost Optimization)

Why it matters. An unattached disk is billed every month for its full size but serves no workload. They are usually left behind when virtual machines are deleted.

Fix. Snapshot the disk if its data may be needed, then delete it.

1. Confirm with the owner that the data is not needed, or take a snapshot first.
2. Delete the disk.

```
az disk delete -g <resource-group> -n <disk>
```

NAME	EVIDENCE	RESOURCE ID
disk-sqlvm-data-old	**₹12,480 a month, billed** **resourceGroup**: rg-shop-db-prod-cin **location**: centralindia **diskState**: Unattached **sizeGb**: 1024 **sku**: Premium_LRS	`/subscriptions/00000000-0000-0000-0000-00000000d001/resourceGroups/rg-shop-db-prod-cin/providers/Microsoft.Compute/disks/disk-sqlvm-data-old`
disk-vm-erp-01-os	**₹3,105 a month, billed** **resourceGroup**: rg-shop-app-prod-cin **location**: centralindia **diskState**: Unattached **sizeGb**: 256 **sku**: Premium_LRS	`/subscriptions/00000000-0000-0000-0000-00000000d001/resourceGroups/rg-shop-app-prod-cin/providers/Microsoft.Compute/disks/disk-vm-erp-01-os`
disk-uat-restore-test	**₹3,410 a month, billed** **resourceGroup**: rg-shop-app-uat-cin **location**: centralindia **diskState**: Unattached **sizeGb**: 512 **sku**: StandardSSD_LRS	`/subscriptions/00000000-0000-0000-0000-00000000d002/resourceGroups/rg-shop-app-uat-cin/providers/Microsoft.Compute/disks/disk-uat-restore-test`
disk-vm-uat-02-data	**₹3,890 a month, billed** **resourceGroup**: rg-shop-app-uat-cin **location**: centralindia **diskState**: Unattached **sizeGb**: 1024 **sku**: Standard_LRS	`/subscriptions/00000000-0000-0000-0000-00000000d002/resourceGroups/rg-shop-app-uat-cin/providers/Microsoft.Compute/disks/disk-vm-uat-02-data`
disk-jumpbox-old-os	**₹1,540 a month, billed** **resourceGroup**: rg-platform-tools-cin **location**: centralindia **diskState**: Unattached **sizeGb**: 128 **sku**: Premium_LRS	`/subscriptions/00000000-0000-0000-0000-00000000d003/resourceGroups/rg-platform-tools-cin/providers/Microsoft.Compute/disks/disk-jumpbox-old-os`

Reference: https://learn.microsoft.com/azure/virtual-machines/disks-find-unattached-portal

MEDIUM Failed: No paid App Service plans without apps

AZ-COST-005 · Cost · 2 resource(s) · **₹14,770 a month, billed**

Maps to: WAF CO:07 (Cost Optimization)

Why it matters. A paid App Service plan is billed whether or not any app runs on it. Empty plans are usually left over after apps are moved or deleted.

Fix. Delete empty plans, or move apps from other plans onto them.

```
az appservice plan delete -g <resource-group> -n <plan>
```

NAME	EVIDENCE	RESOURCE ID
asp-shop-legacy-prod	**₹9,850 a month, billed** **resourceGroup**: rg-shop-web-prod-cin **location**: centralindia **tier**: PremiumV3 **skuName**: P2v3 **sites**: 0	/subscriptions/00000000-0000-0000-0000-00000000d001/resourceGroups/rg-shop-web-prod-cin/providers/Microsoft.Web/serverfarms/asp-shop-legacy-prod
asp-shop-uat	**₹4,920 a month, billed** **resourceGroup**: rg-shop-web-uat-cin **location**: centralindia **tier**: Standard **skuName**: S1 **sites**: 0	/subscriptions/00000000-0000-0000-0000-00000000d002/resourceGroups/rg-shop-web-uat-cin/providers/Microsoft.Web/serverfarms/asp-shop-uat

Reference: https://learn.microsoft.com/azure/app-service/overview-hosting-plans

MEDIUM Failed: No NAT gateways without a subnet

AZ-COST-006 · Cost · 2 resource(s) · **₹5,910 a month, billed**

Maps to: WAF CO:07 (Cost Optimization)

Why it matters. A NAT gateway is billed every hour it exists, whether or not any subnet uses it. One left behind after a migration or test keeps costing money and holds public IP addresses.

Fix. Delete NAT gateways that no subnet uses, after checking nothing is about to use them.

1. Confirm with the owner that the gateway is not about to be attached to a subnet.
2. Delete the gateway, then delete any public IP addresses or prefixes that only it used.

```
az network nat gateway delete -g <resource-group> -n <nat-gateway>
```

NAME	EVIDENCE	RESOURCE ID
natgw-uat-spike	**₹2,790 a month, billed** **resourceGroup**: rg-shop-net-uat-cin **location**: centralindia **sku**: Standard **subnetCount**: 0	/subscriptions/00000000-0000-0000-0000-00000000d002/resourceGroups/rg-shop-net-uat-cin/providers/Microsoft.Network/natGateways/natgw-uat-spike
natgw-shop-old-prod	**₹3,120 a month, billed** **resourceGroup**: rg-shop-net-prod-cin **location**: centralindia **sku**: Standard **subnetCount**: 0	/subscriptions/00000000-0000-0000-0000-00000000d001/resourceGroups/rg-shop-net-prod-cin/providers/Microsoft.Network/natGateways/natgw-shop-old-prod

Reference: https://learn.microsoft.com/azure/nat-gateway/nat-overview · https://azure.microsoft.com/pricing/details/virtual-network/

MEDIUM Failed: Azure AI services accounts disable key-based authentication

AZ-AI-001 · Identity · 1 resource(s)

Maps to: MCSB IM-1 · WAF SE:05 (Security)

Why it matters. An API key lets anyone who holds it call the service on your bill and, for Azure OpenAI, send it your data and prompts. Keys leak through code and config files and do not say who used them. Entra ID access is scoped, audited and removed when no longer needed.

Fix. Move applications to Entra ID authentication, then disable key-based access.

1. Give the account a custom subdomain if it has none (Entra ID authentication needs one).
2. Grant each application a role such as Cognitive Services User and switch it to its managed identity.
3. Disable local (key-based) authentication on the account.

```
az resource update --ids <account-id> --set properties.disableLocalAuth=true
```

NAME	EVIDENCE	RESOURCE ID
oai-shop-support-prod-cin	**resourceGroup**: rg-shop-app-prod-cin **location**: centralindia **serviceKind**: OpenAI **disableLocalAuth**: false	/subscriptions/00000000-0000-0000-0000-00000000d001/resourceGroups/rg-shop-app-prod-cin/providers/Microsoft.CognitiveServices/accounts/oai-shop-support-prod-cin

Reference: https://learn.microsoft.com/azure/ai-services/disable-local-auth

MEDIUM Failed: Cosmos DB accounts disable key-based authentication

AZ-COSMOS-001 · Identity · 2 resource(s)

Maps to: MCSB IM-1 · WAF SE:05 (Security)

Why it matters. An account key gives full read and write access to every database in the account, never expires on its own, and does not say who used it. Keys end up in config files and scripts and are hard to rotate. Entra ID roles are scoped, audited and removed when a person leaves.

Fix. Move applications to Entra ID role-based access, then disable key-based authentication.

1. Grant each application a Cosmos DB data-plane role (for example Cosmos DB Built-in Data Contributor).
2. Change the applications to authenticate with their managed identity instead of a key.
3. Disable local (key-based) authentication on the account.

```
az cosmosdb update -g <resource-group> -n <account> --disable-local-auth true
```

NAME	EVIDENCE	RESOURCE ID
cosmos-shop-catalog-prod-cin	**resourceGroup**: rg-shop-data-prod-cin **location**: centralindia **apiKind**: GlobalDocumentDB **disableLocalAuth**: false	/subscriptions/00000000-0000-0000-0000-00000000d001/resourceGroups/rg-shop-data-prod-cin/providers/Microsoft.DocumentDB/databaseAccounts/cosmos-shop-catalog-prod-cin
cosmos-shop-catalog-uat-cin	**resourceGroup**: rg-shop-data-uat-cin **location**: centralindia **apiKind**: GlobalDocumentDB **disableLocalAuth**: false	/subscriptions/00000000-0000-0000-0000-00000000d002/resourceGroups/rg-shop-data-uat-cin/providers/Microsoft.DocumentDB/databaseAccounts/cosmos-shop-catalog-uat-cin

Reference: https://learn.microsoft.com/azure/cosmos-db/how-to-setup-rbac#disable-local-auth

MEDIUM Failed: Service Bus and Event Hubs namespaces disable SAS key authentication

AZ-MSG-001 · Identity · 1 resource(s)

Maps to: MCSB IM-1 · WAF SE:05 (Security)

Why it matters. A shared access signature key lets anyone who holds it send or read messages, does not say who used it, and usually sits in connection strings in config files. Entra ID roles are scoped to a queue or topic, audited, and removed when an app or person no longer needs them.

Fix. Move clients to Entra ID role-based access, then disable local (SAS) authentication.

1. Grant each application a data role, for example Azure Service Bus Data Sender or Azure Event Hubs Data Receiver.
2. Change the applications to authenticate with their managed identity instead of a connection string.
3. Disable local authentication on the namespace (for Event Hubs, az eventhubs namespace update with the same flag).

```
az servicebus namespace update -g <resource-group> -n <namespace> --disable-local-auth true
```

NAME	EVIDENCE	RESOURCE ID
sb-shop-orders-prod-cin	**resourceGroup**: rg-shop-app-prod-cin **location**: centralindia **service**: Service Bus **sku**: Standard **disableLocalAuth**: false	`/subscriptions/00000000-0000-0000-0000-00000000d001/resourceGroups/rg-shop-app-prod-cin/providers/Microsoft.ServiceBus/namespaces/sb-shop-orders-prod-cin`

Reference: https://learn.microsoft.com/azure/service-bus-messaging/disable-local-authentication · https://learn.microsoft.com/azure/event-hubs/authenticate-shared-access-signature

MEDIUM Failed: Container registries are not open to all networks

AZ-ACR-003 · Network · 1 resource(s)

Maps to: MCSB NS-2 · WAF SE:06 (Security)

Why it matters. A registry that accepts connections from any network can be pushed to or pulled from anywhere on the Internet with a leaked credential. A poisoned image pushed this way runs in every cluster and app that pulls it.

Fix. Use private endpoints, or limit the registry firewall to known networks (Premium SKU).

1. Upgrade the registry to Premium if it is Basic or Standard.
2. Add a private endpoint, or firewall rules for the build agents and clusters that use the registry.
3. Set public network access to Disabled, or the default action to Deny.

```
az acr update -n <registry> --public-network-enabled false
```

NAME	EVIDENCE	RESOURCE ID
acrplatformcin	**resourceGroup**: rg-platform-tools-cin **location**: centralindia **sku**: Standard **publicNetworkAccess**: Enabled **defaultAction**: Allow	`/subscriptions/00000000-0000-0000-0000-00000000d003/resourceGroups/rg-platform-tools-cin/providers/Microsoft.ContainerRegistry/registries/acrplatformcin`

Reference: https://learn.microsoft.com/azure/container-registry/container-registry-access-selected-networks · https://learn.microsoft.com/azure/container-registry/container-registry-private-link

MEDIUM Failed: Every subnet has a network security group

AZ-NET-003 · Network · 3 resource(s)

Maps to: MCSB NS-1 · WAF SE:06, SE:04 (Security)

Why it matters. A subnet with no network security group lets any machine in it be reached from the rest of the network, and from the Internet if it has a public address. A group gives you a rule set you can see and review.

Fix. Attach a network security group to each subnet, starting with deny-by-default inbound rules.

1. Create or choose a network security group for the subnet's role.
2. Allow only the traffic the workload needs, then associate the group with the subnet.

```
az network vnet subnet update -g <resource-group> --vnet-name <vnet> -n <subnet> --network-security-group <nsg>
```

NAME	EVIDENCE	RESOURCE ID
snet-app-prod	**resourceGroup**: rg-shop-net-prod-cin **location**: centralindia **vnet**: vnet-shop-prod-cin **nsgId**:	/subscriptions/00000000-0000-0000-0000-00000000d001/resourceGroups/rg-shop-net-prod-cin/providers/Microsoft.Network/virtualNetworks/vnet-shop-prod-cin/subnets/snet-app-prod
snet-aks-uat	**resourceGroup**: rg-shop-net-uat-cin **location**: centralindia **vnet**: vnet-shop-uat-cin **nsgId**:	/subscriptions/00000000-0000-0000-0000-00000000d002/resourceGroups/rg-shop-net-uat-cin/providers/Microsoft.Network/virtualNetworks/vnet-shop-uat-cin/subnets/snet-aks-uat
snet-shared-services	**resourceGroup**: rg-platform-net-cin **location**: centralindia **vnet**: vnet-platform-hub-cin **nsgId**:	/subscriptions/00000000-0000-0000-0000-00000000d003/resourceGroups/rg-platform-net-cin/providers/Microsoft.Network/virtualNetworks/vnet-platform-hub-cin/subnets/snet-shared-services

Reference: https://learn.microsoft.com/azure/virtual-network/network-security-groups-overview

MEDIUM Failed: AKS node pools are spread across availability zones

AZ-AKS-005 · Reliability · 2 resource(s)

Maps to: WAF RE:05 (Reliability)

Why it matters. A node pool in a single zone goes down with that zone. Spreading nodes across zones keeps workloads running through a datacentre outage.

Fix. Create node pools across at least two availability zones (zones are set at creation).

1. Check the region supports availability zones.
2. Create a replacement pool with zones 1, 2 and 3, move workloads, then remove the old pool.

```
az aks nodepool add -g <resource-group> --cluster-name <cluster> -n pool2 --zones 1 2 3
```

NAME	EVIDENCE	RESOURCE ID
aks-shop-prod-cin	**resourceGroup**: rg-shop-aks-prod-cin **location**: centralindia **pools**: 1 **poolsWithoutZones**: 1	/subscriptions/00000000-0000-0000-0000-00000000d001/resourceGroups/rg-shop-aks-prod-cin/providers/Microsoft.ContainerService/managedClusters/aks-shop-prod-cin
aks-shop-uat-cin	**resourceGroup**: rg-shop-aks-uat-cin **location**: centralindia **pools**: 2 **poolsWithoutZones**: 2	/subscriptions/00000000-0000-0000-0000-00000000d002/resourceGroups/rg-shop-aks-uat-cin/providers/Microsoft.ContainerService/managedClusters/aks-shop-uat-cin

Reference: https://learn.microsoft.com/azure/aks/availability-zones

MEDIUM Failed: AKS clusters have an automatic upgrade channel set

AZ-AKS-007 · Reliability · 1 resource(s)

Maps to: MCSB PV-6 · WAF SE:08 (Security)

Why it matters. A cluster with no upgrade channel stays on its Kubernetes version until someone remembers to upgrade it. Old versions fall out of support and miss security patches.

Fix. Set an automatic upgrade channel, for example patch or stable.

1. Pick a channel. "patch" applies only security and bug-fix releases and is the safest start.
2. Set a planned maintenance window so upgrades happen at a quiet time.

```
az aks update -g <resource-group> -n <cluster> --auto-upgrade-channel patch
```

NAME	EVIDENCE	RESOURCE ID
aks-shop-prod-cin	**resourceGroup**: rg-shop-aks-prod-cin **location**: centralindia **upgradeChannel**: none	/subscriptions/00000000-0000-0000-0000-00000000d001/resourceGroups/rg-shop-aks-prod-cin/providers/Microsoft.ContainerService/managedClusters/aks-shop-prod-cin

Reference: https://learn.microsoft.com/azure/aks/auto-upgrade-cluster

MEDIUM Failed: Production AKS clusters use the Standard tier with an uptime SLA

AZ-REL-001 · Reliability · 1 resource(s)

Maps to: WAF pillar Reliability

Why it matters. The Free tier has no financially backed uptime SLA for the control plane. Production clusters need the Standard tier so the API server stays available under load.

Fix. Move production clusters to the Standard tier.

```
az aks update -g <resource-group> -n <cluster> --tier standard
```

NAME	EVIDENCE	RESOURCE ID
aks-shop-prod-cin	**resourceGroup**: rg-shop-aks-prod-cin **location**: centralindia **environment**: prod **tier**: Free	/subscriptions/00000000-0000-0000-0000-00000000d001/resourceGroups/rg-shop-aks-prod-cin/providers/Microsoft.ContainerService/managedClusters/aks-shop-prod-cin

Reference: https://learn.microsoft.com/azure/aks/free-standard-pricing-tiers

MEDIUM Failed: Production virtual machines are in an availability zone

AZ-REL-002 · Reliability · 1 resource(s)

Maps to: WAF RE:05 (Reliability)

Why it matters. A virtual machine outside an availability zone can be lost with a single datacentre fault. Zones keep a production workload running when one building has a power or cooling failure.

Fix. Recreate the VM in an availability zone (a VM's zone cannot be changed in place).

1. Check the region supports availability zones.
2. Snapshot the disks, create the VM in a zone from the snapshots, then cut traffic over.
3. For real resilience, run two or more VMs in different zones behind a load balancer.

```
az vm create -g <resource-group> -n <vm> --image <image> --zone 1
```

NAME	EVIDENCE	RESOURCE ID
vm-web-01	**resourceGroup**: rg-shop-app-prod-cin **location**: centralindia **environment**: prod **zones**: null **zoneCount**: 0	/subscriptions/00000000-0000-0000-0000-00000000d001/resourceGroups/rg-shop-app-prod-cin/providers/Microsoft.Compute/virtualMachines/vm-web-01

Reference: https://learn.microsoft.com/azure/reliability/reliability-virtual-machines

MEDIUM Failed: Production storage accounts use zone- or geo-redundant replication

AZ-REL-003 · Reliability · 1 resource(s)

Maps to: WAF RE:05 (Reliability)

Why it matters. Locally redundant storage keeps all copies in one datacentre. A fire or flood there can lose production data. Zone or geo replication keeps copies in separate buildings or regions.

Fix. Change the replication type to ZRS, GRS or GZRS.

1. Pick ZRS for protection inside the region, or GZRS for protection across regions too.
2. Change the redundancy setting on the account; Azure converts it online or on request.

```
az storage account update -g <resource-group> -n <account> --sku Standard_ZRS
```

NAME	EVIDENCE	RESOURCE ID
stshopordersprodcin	**resourceGroup**: rg-shop-data-prod-cin **location**: centralindia **environment**: prod **skuName**: Standard_LRS	/subscriptions/00000000-0000-0000-0000-00000000d001/resourceGroups/rg-shop-data-prod-cin/providers/Microsoft.Storage/storageAccounts/stshopordersprodcin

Reference: https://learn.microsoft.com/azure/storage/common/redundancy-migration

MEDIUM Failed: Storage accounts disable shared key access

AZ-STG-004 · Security · 3 resource(s)

Maps to: MCSB IM-1 · WAF SE:05 (Security)

Why it matters. An account key gives full control of everything in the account and cannot be limited to one person or one task. Turning shared key access off forces clients to use Microsoft Entra identities, which can be scoped, audited and revoked.

Fix. Disallow shared key authorization on the storage account.

1. Move applications and tools to Microsoft Entra authentication (managed identity and RBAC roles).
2. Check that nothing still uses account keys or key-signed SAS tokens; they stop working once this is off.
3. Set "Allow storage account key access" to Disabled in the account's Configuration settings.

```
az storage account update -g <resource-group> -n <account> --allow-shared-key-access false
```

NAME	EVIDENCE	RESOURCE ID
stshopmediaprodcin	**resourceGroup**: rg-shop-data-prod-cin **location**: centralindia **allowSharedKeyAccess**: true	/subscriptions/00000000-0000-0000-0000-00000000d001/resourceGroups/rg-shop-data-prod-cin/providers/Microsoft.Storage/storageAccounts/stshopmediaprodcin
stshopstaticprodcin	**resourceGroup**: rg-shop-web-prod-cin **location**: centralindia **allowSharedKeyAccess**: null	/subscriptions/00000000-0000-0000-0000-00000000d001/resourceGroups/rg-shop-web-prod-cin/providers/Microsoft.Storage/storageAccounts/stshopstaticprodcin
stshopexportsuatcin	**resourceGroup**: rg-shop-data-uat-cin **location**: centralindia **allowSharedKeyAccess**: true	/subscriptions/00000000-0000-0000-0000-00000000d002/resourceGroups/rg-shop-data-uat-cin/providers/Microsoft.Storage/storageAccounts/stshopexportsuatcin

Reference: https://learn.microsoft.com/azure/storage/common/shared-key-authorization-prevent

MEDIUM Failed: Storage accounts block cross-tenant object replication

AZ-STG-005 · Security · 2 resource(s)

Maps to: MCSB PV-2 · WAF SE:08 (Security)

Why it matters. Object replication can copy every blob in a container to a storage account in another Entra tenant. Anyone who can set up a replication policy could then move your data out of your organisation's control without it looking like a download.

Fix. Turn off "Allow cross-tenant replication" on each account that does not need it.

1. Check whether the account has object replication policies to an account in another tenant.
2. If none are needed, turn off "Allow cross-tenant replication" in the account's Object replication settings.

```
az storage account update -g <resource-group> -n <account> --allow-cross-tenant-replication false
```

NAME	EVIDENCE	RESOURCE ID
stshopexportsuatcin	**resourceGroup**: rg-shop-data-uat-cin **location**: centralindia **allowCrossTenantReplication**: true	/subscriptions/00000000-0000-0000-0000-00000000d002/resourceGroups/rg-shop-data-uat-cin/providers/Microsoft.Storage/storageAccounts/stshopexportsuatcin
stplatformlogscin	**resourceGroup**: rg-platform-logs-cin **location**: centralindia **allowCrossTenantReplication**: null	/subscriptions/00000000-0000-0000-0000-00000000d003/resourceGroups/rg-platform-logs-cin/providers/Microsoft.Storage/storageAccounts/stplatformlogscin

Reference: https://learn.microsoft.com/azure/storage/blobs/object-replication-prevent-cross-tenant-policies

MEDIUM Failed: Virtual machines use Trusted Launch

AZ-VM-002 · Security · 2 resource(s)

Maps to: MCSB PV-4 · WAF SE:08 (Security)

Why it matters. Without Trusted Launch a VM has no secure boot and no virtual TPM, so malware that installs itself in the boot chain (a bootkit or rootkit) can load before the operating system and its defences, and stay hidden from them.

Fix. Enable Trusted Launch with secure boot and vTPM.

1. Check the VM is Generation 2 and its size supports Trusted Launch.
2. Take a backup, stop (deallocate) the VM and upgrade its security type to Trusted Launch.
3. Turn on secure boot and vTPM and start the VM.

```
az vm update -g <resource-group> -n <vm> --security-type TrustedLaunch --enable-secure-boot true --enable-vtpm true
```

NAME	EVIDENCE	RESOURCE ID
vm-uat-02	**resourceGroup**: rg-shop-app-uat-cin **location**: centralindia **securityType**: Standard **secureBoot**: null **vTpm**: null	/subscriptions/00000000-0000-0000-0000-00000000d002/resourceGroups/rg-shop-app-uat-cin/providers/Microsoft.Compute/virtualMachines/vm-uat-02
vm-buildagent-01	**resourceGroup**: rg-platform-tools-cin **location**: centralindia **securityType**: Standard **secureBoot**: null **vTpm**: null	/subscriptions/00000000-0000-0000-0000-00000000d003/resourceGroups/rg-platform-tools-cin/providers/Microsoft.Compute/virtualMachines/vm-buildagent-01

Reference: https://learn.microsoft.com/azure/virtual-machines/trusted-launch · https://learn.microsoft.com/azure/virtual-machines/trusted-launch-existing-vm

MEDIUM Failed: Managed disks cannot be exported from any network

AZ-VM-004 · Security · 7 resource(s)

Maps to: MCSB NS-2 · WAF SE:06 (Security)

Why it matters. With AllowAll, anyone allowed to export a disk can create a download link (a SAS URL) for it and copy the whole disk, with all its data, from anywhere on the Internet. Limiting export to a private network, or blocking it, stops a full copy of a server leaving that way.

Fix. Set each disk's network access to Deny all, or to private access through a disk access resource.

1. Check whether anyone needs to export or import the disk (backups through Azure Backup are not affected).
2. Set network access to Disable public and private access, or to private access only.

```
az disk update -g <resource-group> -n <disk> --network-access-policy DenyAll
```

NAME	EVIDENCE	RESOURCE ID
disk-sqlvm-data-old	**resourceGroup**: rg-shop-db-prod-cin **location**: centralindia **diskState**: Unattached **networkAccessPolicy**: AllowAll **publicNetworkAccess**: Enabled	/subscriptions/00000000-0000-0000-0000-00000000d001/resourceGroups/rg-shop-db-prod-cin/providers/Microsoft.Compute/disks/disk-sqlvm-data-old
disk-vm-erp-01-os	**resourceGroup**: rg-shop-app-prod-cin **location**: centralindia **diskState**: Unattached **networkAccessPolicy**: AllowAll **publicNetworkAccess**: Enabled	/subscriptions/00000000-0000-0000-0000-00000000d001/resourceGroups/rg-shop-app-prod-cin/providers/Microsoft.Compute/disks/disk-vm-erp-01-os
disk-uat-restore-test	**resourceGroup**: rg-shop-app-uat-cin **location**: centralindia **diskState**: Unattached **networkAccessPolicy**: AllowAll **publicNetworkAccess**: Enabled	/subscriptions/00000000-0000-0000-0000-00000000d002/resourceGroups/rg-shop-app-uat-cin/providers/Microsoft.Compute/disks/disk-uat-restore-test
disk-vm-uat-02-data	**resourceGroup**: rg-shop-app-uat-cin **location**: centralindia **diskState**: Unattached **networkAccessPolicy**: AllowAll **publicNetworkAccess**: Enabled	/subscriptions/00000000-0000-0000-0000-00000000d002/resourceGroups/rg-shop-app-uat-cin/providers/Microsoft.Compute/disks/disk-vm-uat-02-data
disk-jumpbox-old-os	**resourceGroup**: rg-platform-tools-cin **location**: centralindia **diskState**: Unattached **networkAccessPolicy**: AllowAll **publicNetworkAccess**: Enabled	/subscriptions/00000000-0000-0000-0000-00000000d003/resourceGroups/rg-platform-tools-cin/providers/Microsoft.Compute/disks/disk-jumpbox-old-os
disk-vm-uat-02-os	**resourceGroup**: rg-shop-app-uat-cin **location**: centralindia **diskState**: Attached **networkAccessPolicy**: AllowAll **publicNetworkAccess**: Enabled	/subscriptions/00000000-0000-0000-0000-00000000d002/resourceGroups/rg-shop-app-uat-cin/providers/Microsoft.Compute/disks/disk-vm-uat-02-os
disk-vm-buildagent-01-os	**resourceGroup**: rg-platform-tools-cin **location**: centralindia **diskState**: Attached **networkAccessPolicy**: AllowAll **publicNetworkAccess**: Enabled	/subscriptions/00000000-0000-0000-0000-00000000d003/resourceGroups/rg-platform-tools-cin/providers/Microsoft.Compute/disks/disk-vm-buildagent-01-os

Reference: https://learn.microsoft.com/azure/virtual-machines/disks-restrict-import-export-overview

MEDIUM Failed: App Service apps require TLS 1.2 or later

AZ-WEB-002 · Security · 1 resource(s)

Maps to: MCSB DP-3 · WAF SE:07 (Security)

Why it matters. TLS 1.0 and 1.1 have known weaknesses and fail most security reviews and payment-card audits. An app that still accepts them lets clients connect over weaker encryption.

Fix. Set the app's minimum inbound TLS version to 1.2.

1. Confirm the app's clients support TLS 1.2 (all current browsers and SDKs do).
2. Set "Minimum Inbound TLS Version" to 1.2 in the app's Configuration > General settings.

```
az webapp config set -g <resource-group> -n <app> --min-tls-version 1.2
```

NAME	EVIDENCE	RESOURCE ID
app-shop-legacy-prod	**resourceGroup**: rg-shop-web-prod-cin **location**: centralindia **appKind**: app **minTlsVersion**: 1.0	/subscriptions/00000000-0000-0000-0000-00000000d001/resourceGroups/rg-shop-web-prod-cin/providers/Microsoft.Web/sites/app-shop-legacy-prod

Reference: https://learn.microsoft.com/azure/app-service/overview-tls

MEDIUM Failed: App Service apps do not allow plain FTP

AZ-WEB-004 · Security · 1 resource(s)

Maps to: MCSB DP-3 · WAF SE:07 (Security)

Why it matters. Plain FTP sends deployment credentials and code unencrypted. Anyone on the network path can capture them and deploy their own code to the app.

Fix. Set FTP state to "FTPS only", or "Disabled" if nobody deploys over FTP.

1. Check whether any pipeline or person still deploys over FTP.
2. Set "FTP state" in the app's Configuration > General settings.

```
az webapp config set -g <resource-group> -n <app> --ftps-state Disabled
```

NAME	EVIDENCE	RESOURCE ID
app-shop-legacy-prod	**resourceGroup**: rg-shop-web-prod-cin **location**: centralindia **appKind**: app **ftpsState**: AllAllowed	/subscriptions/00000000-0000-0000-0000-00000000d001/resourceGroups/rg-shop-web-prod-cin/providers/Microsoft.Web/sites/app-shop-legacy-prod

Reference: https://learn.microsoft.com/azure/app-service/deploy-ftp

MEDIUM Failed: App Service apps do not allow CORS requests from every origin

AZ-WEB-006 · Security · 2 resource(s)

Maps to: MCSB PV-2 · WAF SE:08 (Security)

Why it matters. An allowed origin of * lets any website, including a malicious one a user happens to visit, call the app from that user's browser and read the responses. Listing only your own front-end addresses keeps other sites from using the app's API.

Fix. Replace * with the exact origins of your own front ends.

1. List the websites that call this app from a browser.
2. In the app's CORS settings, remove * and add those origins only.

```
az webapp cors remove -g <resource-group> -n <app> --allowed-origins "*"
```

NAME	EVIDENCE	RESOURCE ID
app-shop-legacy-prod	**resourceGroup**: rg-shop-web-prod-cin **location**: centralindia **appKind**: app **corsAllowedOrigins**: ["*"]	/subscriptions/00000000-0000-0000-0000-00000000d001/resourceGroups/rg-shop-web-prod-cin/providers/Microsoft.Web/sites/app-shop-legacy-prod
app-shop-uat	**resourceGroup**: rg-shop-web-uat-cin **location**: centralindia **appKind**: app,linux **corsAllowedOrigins**: ["*"]	/subscriptions/00000000-0000-0000-0000-00000000d002/resourceGroups/rg-shop-web-uat-cin/providers/Microsoft.Web/sites/app-shop-uat

Reference: https://learn.microsoft.com/azure/app-service/app-service-web-tutorial-rest-api#add-cors-functionality

LOW Failed: No unused public IP addresses

AZ-COST-002 · Cost · 5 resource(s) · **₹1,528 a month, ₹1,208 billed, ₹320 list-price estimate**

Maps to: WAF CO:07 (Cost Optimization)

Why it matters. A static public IP that is not attached to anything is still billed, and an unused public address is easy to forget and later attach to the wrong resource.

Fix. Delete public IPs that are not attached to a network interface, load balancer or NAT gateway.

```
az network public-ip delete -g <resource-group> -n <public-ip>
```

NAME	EVIDENCE	RESOURCE ID
pip-lb-old-checkout	**₹302 a month, billed** **resourceGroup**: rg-shop-net-prod-cin **location**: centralindia **sku**: Standard **allocation**: Static	/subscriptions/00000000-0000-0000-0000-00000000d001/resourceGroups/rg-shop-net-prod-cin/providers/Microsoft.Network/publicIPAddresses/pip-lb-old-checkout
pip-vm-erp-01	**₹302 a month, billed** **resourceGroup**: rg-shop-app-prod-cin **location**: centralindia **sku**: Standard **allocation**: Static	/subscriptions/00000000-0000-0000-0000-00000000d001/resourceGroups/rg-shop-app-prod-cin/providers/Microsoft.Network/publicIPAddresses/pip-vm-erp-01
pip-uat-test-1	**₹302 a month, billed** **resourceGroup**: rg-shop-app-uat-cin **location**: centralindia **sku**: Standard **allocation**: Static	/subscriptions/00000000-0000-0000-0000-00000000d002/resourceGroups/rg-shop-app-uat-cin/providers/Microsoft.Network/publicIPAddresses/pip-uat-test-1
pip-uat-test-2	**₹302 a month, billed** **resourceGroup**: rg-shop-app-uat-cin **location**: centralindia **sku**: Standard **allocation**: Static	/subscriptions/00000000-0000-0000-0000-00000000d002/resourceGroups/rg-shop-app-uat-cin/providers/Microsoft.Network/publicIPAddresses/pip-uat-test-2
pip-vpn-trial	**₹320 a month, list-price estimate** **resourceGroup**: rg-platform-tools-cin **location**: centralindia **sku**: Standard **allocation**: Static	/subscriptions/00000000-0000-0000-0000-00000000d003/resourceGroups/rg-platform-tools-cin/providers/Microsoft.Network/publicIPAddresses/pip-vpn-trial

Reference: https://learn.microsoft.com/azure/virtual-network/ip-services/public-ip-addresses

LOW Failed: No disk snapshots older than 90 days

AZ-COST-004 · Cost · 3 resource(s) · **₹7,035 a month, billed**

Maps to: WAF CO:07, CO:10 (Cost Optimization)

Why it matters. Snapshots are often taken before a change and then forgotten. Old snapshots keep billing every month long after anyone could need them.

Fix. Delete snapshots that are no longer needed, and use Azure Backup policies for retention.

```
az snapshot delete -g <resource-group> -n <snapshot>
```

NAME	EVIDENCE	RESOURCE ID
snap-sqlvm-before-migration	**₹3,980 a month, billed** **resourceGroup**: rg-shop-db-prod-cin **location**: centralindia **sizeGb**: 1024 **ageDays**: 412	/subscriptions/00000000-0000-0000-0000-00000000d001/resourceGroups/rg-shop-db-prod-cin/providers/Microsoft.Compute/snapshots/snap-sqlvm-before-migration
snap-erp-pre-upgrade	**₹1,010 a month, billed** **resourceGroup**: rg-shop-app-prod-cin **location**: centralindia **sizeGb**: 256 **ageDays**: 230	/subscriptions/00000000-0000-0000-0000-00000000d001/resourceGroups/rg-shop-app-prod-cin/providers/Microsoft.Compute/snapshots/snap-erp-pre-upgrade
snap-uat-golden-image	**₹2,045 a month, billed** **resourceGroup**: rg-shop-app-uat-cin **location**: centralindia **sizeGb**: 512 **ageDays**: 140	/subscriptions/00000000-0000-0000-0000-00000000d002/resourceGroups/rg-shop-app-uat-cin/providers/Microsoft.Compute/snapshots/snap-uat-golden-image

Reference: https://learn.microsoft.com/azure/virtual-machines/snapshot-copy-managed-disk

LOW Failed: No Premium SSD disks on deallocated virtual machines

AZ-COST-007 · Cost · 1 resource(s) · **₹1,536 a month, list-price estimate**

Maps to: WAF CO:07 (Cost Optimization)

Why it matters. A deallocated VM stops compute charges, but its disks are billed in full. A Premium SSD on a VM that stays off for long periods costs about twice a Standard SSD of the same size.

Fix. Move disks of long-term deallocated VMs to Standard SSD, or delete the VM if no longer needed.

1. Confirm the VM will stay off for weeks, not days (the change needs the VM to be deallocated).
2. Change the disk's performance tier to Standard SSD, and change it back before the VM returns to production.

```
az disk update -g <resource-group> -n <disk> --sku StandardSSD_LRS
```

NAME	EVIDENCE	RESOURCE ID
disk-vm-uat-02-os	**₹1,536 a month, list-price estimate** **resourceGroup**: rg-shop-app-uat-cin **location**: centralindia **vm**: vm-uat-02 **powerState**: PowerState/deallocated **sizeGb**: 256 **sku**: Premium_LRS	/subscriptions/00000000-0000-0000-0000-00000000d002/resourceGroups/rg-shop-app-uat-cin/providers/Microsoft.Compute/disks/disk-vm-uat-02-os

Reference: https://learn.microsoft.com/azure/virtual-machines/disks-convert-types

LOW Failed: No private DNS zones without a virtual network link

AZ-COST-008 · Cost · 2 resource(s) · **₹78 a month, billed**

Maps to: WAF CO:07 (Cost Optimization)

Why it matters. A private DNS zone answers only for the virtual networks linked to it. A zone with no links resolves nothing for anyone, yet is still billed every month. These are usually left behind after a private endpoint or a network was deleted.

Fix. Delete private DNS zones that no network uses, or link them to the network that needs them.

1. Check with the owner whether a network is about to be linked to the zone.
2. Link the zone to the right virtual network, or delete it.

```
az network private-dns zone delete -g <resource-group> -n <zone>
```

NAME	EVIDENCE	RESOURCE ID
privatelink.vaultcore.azure.net	**₹39 a month, billed** **resourceGroup**: rg-shop-net-uat-cin **location**: global **links**: 0 **recordSets**: 1	/subscriptions/00000000-0000-0000-0000-00000000d002/resourceGroups/rg-shop-net-uat-cin/providers/Microsoft.Network/privateDnsZones/privatelink.vaultcore.azure.net
shop-legacy.internal	**₹39 a month, billed** **resourceGroup**: rg-shop-net-prod-cin **location**: global **links**: 0 **recordSets**: 12	/subscriptions/00000000-0000-0000-0000-00000000d001/resourceGroups/rg-shop-net-prod-cin/providers/Microsoft.Network/privateDnsZones/shop-legacy.internal

Reference: https://learn.microsoft.com/azure/dns/private-dns-virtual-network-links · https://azure.microsoft.com/pricing/details/dns/

LOW Failed: App Service apps use a managed identity

AZ-WEB-003 · Identity · 2 resource(s)

Maps to: MCSB IM-3 · WAF SE:05 (Security)

Why it matters. An app without a managed identity has to keep passwords or keys in its settings to reach databases, Key Vault or storage. A managed identity lets Azure issue the credentials, so there is no secret to leak or rotate.

Fix. Turn on a managed identity for each app and grant it access to what it uses.

1. List the secrets and connection strings the app uses to reach other Azure services.
2. Enable a system-assigned identity, or attach a user-assigned one.
3. Grant that identity the needed role on each service, switch the app to it, and remove the old secret.

```
az webapp identity assign -g <resource-group> -n <app>
```

NAME	EVIDENCE	RESOURCE ID
app-shop-legacy-prod	**resourceGroup**: rg-shop-web-prod-cin **location**: centralindia **identityType**: None **appKind**: app	/subscriptions/00000000-0000-0000-0000-00000000d001/resourceGroups/rg-shop-web-prod-cin/providers/Microsoft.Web/sites/app-shop-legacy-prod
app-shop-uat	**resourceGroup**: rg-shop-web-uat-cin **location**: centralindia **identityType**: None **appKind**: app,linux	/subscriptions/00000000-0000-0000-0000-00000000d002/resourceGroups/rg-shop-web-uat-cin/providers/Microsoft.Web/sites/app-shop-uat

Reference: https://learn.microsoft.com/azure/app-service/overview-managed-identity

LOW Failed: AKS clusters have workload identity enabled

AZ-AKS-010 · Kubernetes (AKS) · 1 resource(s)

Maps to: MCSB IM-3 · WAF SE:05 (Security)

Why it matters. Without workload identity, pods that call Azure usually carry a client secret or connection string, stored as a Kubernetes secret, that can leak and is rarely rotated. Workload identity lets each pod use an Entra ID identity instead, with no secret to steal.

Fix. Enable the OIDC issuer and workload identity, then move pods off stored secrets.

1. Enable the OIDC issuer and workload identity on the cluster.
2. For each app, create a managed identity with a federated credential for its service account.
3. Replace the app's stored secrets with the identity, then delete the secrets.

```
az aks update -g <resource-group> -n <cluster> --enable-oidc-issuer --enable-workload-identity
```

NAME	EVIDENCE	RESOURCE ID
aks-shop-uat-cin	**resourceGroup**: rg-shop-aks-uat-cin **location**: centralindia **workloadIdentity**: null **oidcIssuer**: null	/subscriptions/00000000-0000-0000-0000-00000000d002/resourceGroups/rg-shop-aks-uat-cin/providers/Microsoft.ContainerService/managedClusters/aks-shop-uat-cin

Reference: https://learn.microsoft.com/azure/aks/workload-identity-overview

Appendix A · Passed checks

CHECK	TITLE	AREA	RESOURCES
AZ-ACR-001	Container registries have the admin user disabled	Identity	2
AZ-ACR-002	Container registries do not allow anonymous pull	Security	2
AZ-AKS-003	AKS API server is private or limited to authorised IP ranges	Kubernetes (AKS)	2
AZ-AKS-004	AKS clusters separate system and user node pools	Kubernetes (AKS)	2
AZ-AKS-006	AKS clusters have the Azure Policy add-on enabled	Security	2
AZ-AKS-008	AKS clusters enforce a network policy	Network	2
AZ-AKS-009	AKS clusters have Kubernetes RBAC enabled	Kubernetes (AKS)	2
AZ-COST-003	Stopped virtual machines are deallocated	Cost	4
AZ-KV-002	Key Vaults use the Azure RBAC permission model	Identity	4

CHECK	TITLE	AREA	RESOURCES
AZ-NET-005	Virtual machines have no public IP on their network interface	Network	4
AZ-NET-007	No Basic SKU public IP addresses	Reliability	7
AZ-REDIS-002	Azure Cache for Redis requires TLS 1.2 or later	Security	2
AZ-SQL-004	Azure SQL servers require TLS 1.2 or later	Security	3
AZ-STG-002	Storage accounts require TLS 1.2 or later	Security	5
AZ-STG-003	Storage accounts accept HTTPS only	Security	5
AZ-VM-003	Virtual machines use managed disks	Reliability	4
AZ-WEB-001	App Service apps accept HTTPS only	Security	5
AZ-WEB-005	App Service apps have remote debugging turned off	Security	5

Appendix B · Not scored

None.

Appendix C · Scopes scanned

KIND	ID	NAME
subscription	00000000-0000-0000-0000-00000000d001	sub-shop-prod
subscription	00000000-0000-0000-0000-00000000d002	sub-shop-nonprod
subscription	00000000-0000-0000-0000-00000000d003	sub-platform-shared

Appendix D · Waived

None.

Scores: 100 × weight of passed checks ÷ weight of checks that passed or failed, per area; overall is the average of areas. Weights: critical 10, high 5, medium 3, low 1.

Billed ₹ are what was billed for each resource from 10 Oct to 08 Nov 2026: the average billed day × 30.

1 resource(s) have no billed cost in the period yet and keep their list-price estimate, or show no figure where a check has none.

List-price estimates are per resource and will differ from billed cost.

`findings.json SHA-256: 4fcef511e3de37a8a5c9a0fb5552f778e9095cf68d8e1340443ef6af9692a207`

MCSB control IDs are from the Microsoft cloud security benchmark v2 (preview); the same IDs exist in v1, the default in Microsoft Defender for Cloud. Well-Architected IDs are Skyveda's mapping to Microsoft's published checklists. Skyveda maps to these frameworks; it does not certify compliance.

Want help fixing what this report found? Skyveda offers cloud reviews, fixes and ongoing care in platform engineering, DevOps and reliability: hello@skyvedahq.com · skyvedahq.com

Microsoft and Azure are trademarks of the Microsoft group of companies. Skyveda is not affiliated with or endorsed by Microsoft.